

DataFlow Analytics — SOC 2 Type II Audit Readiness

AI-Powered Business Intelligence SaaS — Trust Services Criteria, 12 Controls, 4 Systems, 5 Evidence Items, 5 Validation Tests

1. Executive Summary

DataFlow Analytics is a 300-employee company providing AI-powered business intelligence solutions to Fortune 500 clients. Enterprise customers are contractually requiring SOC 2 Type II attestation before renewing or signing contracts. This project prepares DataFlow for its first SOC 2 Type II audit by documenting 12 controls against the Trust Services Criteria, cataloging 4 in-scope systems, collecting 5 evidence items, and recording 5 control tests to simulate auditor readiness validation.

2. In-Scope Systems Catalog

System 1: DataFlow BI Platform (Core Application)

Classification	Critical
Owner	VP of Engineering
Description	Main SaaS application (React + Python/FastAPI) used by 180 enterprise companies with 12,000+ active users. Handles authentication, data uploads, ML model processing, and report generation. Runs on AWS ECS using containerized microservices.

System 2: Customer Data Warehouse (PostgreSQL on AWS RDS)

Classification	Critical
Owner	Lead Data Engineer
Description	PostgreSQL on AWS RDS Multi-AZ storing ~8TB of data from 180 client organizations. Tenant-based row-level security, AES-256 encryption with AWS KMS customer-managed keys. Daily automated backups retained for 35 days with 5-minute point-in-time recovery.

System 3: AWS Cloud Infrastructure Account

Classification	Critical
Owner	Director of Infrastructure
Description	Production AWS account hosting ECS clusters, RDS databases, S3 data pipelines, CloudFront CDN, VPC with private subnets, WAF, KMS, CloudTrail audit logging, GuardDuty threat detection, and IAM for 45 engineering staff.

System 4: Okta Identity Provider (SSO & MFA)

Classification	High
Owner	IT Director

Classification	High
Description	Central identity provider for SSO and Adaptive MFA. Admins use YubiKey hardware tokens; employees use TOTP via Okta Verify. Integrated with BambooHR for automated provisioning/deprovisioning. Supports SAML 2.0 federation for enterprise client SSO. 300 employees + 12,000+ client users.

3. SOC 2 Control Catalog — 12 Controls

C-01: Logical Access Control — Role-Based Access

SOC 2: CC6.1 | **NIST CSF 2.0:** PR.AA-01, PR.AA-05

- 5 RBAC roles: Admin (8), Developer (25, read-only prod), Data Engineer (6), Support (12, read-only), Client User (12,000+)
- Access requests via Jira Service Desk with business justification and manager approval
- Quarterly access reviews by role owners; least privilege enforced
- No permanent admin access — temporary privileged access via AWS SSM Session Manager

C-02: Multi-Factor Authentication Enforcement

SOC 2: CC6.1, CC6.6 | **NIST CSF 2.0:** PR.AA-03

- MFA required for all access with no exceptions
- Admins: hardware YubiKey 5 NFC; employees: TOTP via Okta Verify
- Adaptive MFA triggers extra verification for new devices, locations, or off-hours access
- Login blocked if MFA not completed — no bypass possible

C-03: User Provisioning & Deprovisioning

SOC 2: CC6.2, CC6.3 | **NIST CSF 2.0:** PR.AA-01, PR.AA-02

- Automated via Okta + BambooHR integration
- New hires auto-provisioned with correct role based on department/job title
- Terminated employees disabled within 1 hour; all sessions revoked
- Monthly reconciliation report comparing Okta accounts vs BambooHR employee list

C-04: Data Encryption at Rest and in Transit

SOC 2: CC6.7, C1.1 | **NIST CSF 2.0:** PR.DS-01, PR.DS-02

- At rest: AES-256 via AWS KMS customer-managed keys (RDS, S3, EBS)
- In transit: TLS 1.3 required; TLS 1.2 and below disabled on all public endpoints
- RDS parameter group enforces SSL (rds.force_ssl = 1)
- KMS keys rotated automatically every year

C-05: Network Segmentation & Firewall Controls

SOC 2: CC6.6 | **NIST CSF 2.0:** PR.IR-01, PR.IR-04

- ECS runs in private subnets — traffic only through ALB + CloudFront
- RDS in isolated private subnets — accessible only by application layer via security groups

- AWS WAF protects against OWASP Top 10 (SQL injection, XSS)
- Deny-by-default security groups; VPC flow logs sent to CloudWatch

C-06: Vulnerability Management & Patching

SOC 2: CC7.1, CC3.2 | **NIST CSF 2.0:** DE.CM-09, ID.RA-01

- Weekly Qualys scans on all production systems
- Trivy container image scanning in CI/CD — Critical/High CVEs auto-block deployment
- Patch SLAs: Critical (CVSS 9.0+) within 48 hours; High (7.0-8.9) within 14 days
- Annual pen test by Cobalt (Nov 2025): 0 Critical, 1 High (fixed in 5 days), 3 Medium (fixed in 30 days)

C-07: Change Management Process

SOC 2: CC8.1 | **NIST CSF 2.0:** PR.PS-01

- All changes via feature branch + pull request with peer review
- CI/CD pipeline: unit tests (85%+ coverage), Semgrep SAST, container scanning, staging QA
- Infrastructure changes via Terraform with same review/approval process
- Emergency changes require CISO approval + 48-hour post-change review

C-08: Security Monitoring & Alerting (SIEM)

SOC 2: CC7.2, CC7.1 | **NIST CSF 2.0:** DE.AE-02, DE.CM-01

- Datadog SIEM collecting: CloudTrail, VPC Flow Logs, Okta, application logs, RDS audit logs
- Automated alerts: 5+ failed logins in 10 min, admin actions off-hours, large data exports, new geo logins, security group/IAM changes
- High-severity alerts → PagerDuty → on-call engineer (30-min response SLA)

C-09: Incident Response Plan & Procedures

SOC 2: CC7.3, CC7.4 | **NIST CSF 2.0:** RS.MA-01, RS.CO-02

- 4 severity levels (P1-P4) with defined escalation paths and roles (Incident Commander, Tech Lead, Comms Lead)
- Client notification: 24 hours for confidentiality incidents, 4 hours for availability incidents
- Annual tabletop exercise (Jan 2026); post-incident review within 5 business days
- Evidence preservation procedures and regulatory notification requirements documented

C-10: Business Continuity & Disaster Recovery

SOC 2: A1.2, A1.3 | **NIST CSF 2.0:** PR.IR-02, RC.RP-01

- Multi-AZ RDS failover, ECS across 3 AZs with auto-scaling
- DR: primary us-east-1, backup us-west-2; RTO target 2 hours, RPO target 15 minutes
- Latest DR test (Sep 2025): achieved RTO 1.5 hours, RPO 12 minutes (both under target)
- Daily backups retained 35 days; BCP reviewed quarterly, approved by CTO

C-11: Risk Assessment Process

SOC 2: CC3.1, CC3.2 | **NIST CSF 2.0:** ID.RA-01, ID.RA-05

- Annual risk assessment for all in-scope systems using 5x5 likelihood/impact matrix
- Risks mapped to SOC 2 criteria with documented treatment (mitigate, accept, transfer, avoid)
- Most recent assessment: 18 risks identified, all with documented treatments
- Tracked in GRC tool; updated for major changes, new systems, or incidents

C-12: Confidential Data Classification & Handling

SOC 2: C1.1, C1.2 | **NIST CSF 2.0:** PR.DS-10, PR.DS-11

- 3-tier classification: Confidential (client data), Internal (business data), Public (marketing)
- Client data auto-classified as Confidential at upload; encrypted AES-256 + TLS 1.3
- No export to local devices without DLP approval
- Contract termination: cryptographic erasure via KMS key deletion; 90-day retention default; deletion certificate issued

4. Evidence Collection — 5 Evidence Items

Evidence 1: Okta MFA Enrollment & Enforcement Report

Type	System Export
Related Control	C-02: Multi-Factor Authentication
Location	Okta Admin Console > Reports > MFA Enrollment Status

- Shows 100% MFA enrollment for all 300 employees and 12,000+ client users
- Confirms MFA policy set to "Required" with no bypass exceptions
- Verifies admin accounts use YubiKey hardware tokens

Evidence 2: Quarterly Access Review Records

Type	Document
Related Control	C-01: Logical Access Control
Location	Confluence > Security > Access Reviews > Q4-2025 & Q1-2026

- Full user list reviewed per system with reviewer name and completion date
- Role assignments verified against HR job titles; terminated employees checked
- Corrective actions documented (e.g., access removed for role changes)
- System owner sign-off for each review

Evidence 3: AWS CloudTrail Log Integrity & Retention

Type	Screenshot
Related Control	C-08: Security Monitoring (SIEM)
Location	AWS Console > CloudTrail + Datadog SIEM Dashboard

- CloudTrail enabled for all regions; management + data events logged
- Log file validation enabled; S3 bucket with versioning + MFA-delete protection

- Retention: 12 months online, 7 years in Glacier
- Datadog dashboard showing active log collection and alert investigation

Evidence 4: Penetration Test Executive Summary

Type	Report
Related Control	C-06: Vulnerability Management
Location	GRC Tool > Evidence Repository > Cobalt-Nov2025

- Annual pen test by Cobalt (Nov 2025) covering BI platform, AWS infrastructure, authentication
- Testing methods: OWASP Testing Guide + PTES framework
- Results: 0 Critical, 1 High (fixed in 5 days), 3 Medium (fixed in 30 days)
- All findings remediated and retested; executive summary only shared with auditor

Evidence 5: Disaster Recovery Test Report

Type	Report
Related Control	C-10: Business Continuity & DR
Location	Confluence > Infrastructure > DR Tests > Sep-2025

- Simulated complete outage of primary AWS region (us-east-1)
- RTO achieved: 1.5 hours (target: 2 hours); RPO achieved: 12 minutes (target: 15 minutes)
- Issues documented with resolutions; lessons learned and action items tracked
- CTO sign-off confirming test completion and results acceptance

5. Control Testing — 5 Readiness Validation Tests

Test 1: Logical Access Control

- Sampled 30 random user accounts across all in-scope systems
- All 30 had documented Jira access requests with manager approval
- All 30 role assignments matched BambooHR job functions
- Zero terminated employees with active accounts; 3 departures disabled within 1 hour
- Q4 2025 access review completed Dec 12, 2025 with all system owner sign-offs

Test 2: Multi-Factor Authentication Enforcement

- Exported Okta MFA report: 100% of 300 employees have MFA enabled
- Okta policy confirmed: MFA "Required" with zero exception rules
- Login without MFA tested on BI Platform and AWS Console — both denied
- All 8 admin accounts confirmed using YubiKey hardware tokens

Test 3: Change Management Process

- Sampled 15 production changes from GitHub (Nov 2025 – Jan 2026)
- All 15 had pull requests with descriptions and peer review approval

- All 15 passed full CI/CD pipeline (unit tests, SAST, container scan, staging QA)
- Zero direct commits to main branch; 1 emergency change with CISO approval + 48hr review

Test 4: Data Encryption at Rest and in Transit

- RDS encryption confirmed: AES-256 with customer-managed KMS key
- S3 bucket policy blocks unencrypted uploads — tested and verified
- SSL Labs scan: A+ grade; TLS 1.3 supported, TLS 1.0/1.1 disabled
- RDS force_ssl enabled; KMS key rotation active with last rotation date documented

Test 5: Incident Response Plan

- IRP v3.2 (Jan 2026) confirmed current with all required sections
- Tabletop exercise conducted Jan 15, 2026 with 12 participants
- 2 follow-up tasks completed: updated emergency contacts + revised P1 comms template
- Client notification SLAs documented: 24 hours (confidentiality), 4 hours (availability)

6. Audit Readiness Summary

Component	Count	Status	Readiness
SOC 2 Controls	12 documented	All Effective	Ready
In-Scope Systems	4 cataloged	3 Critical, 1 High	Ready
Evidence Items	5 collected	All within audit period	Ready
Control Tests	5 completed	5 Pass, 0 Fail	Ready

7. Next Steps

- **Select audit firm:** Engage a CPA firm experienced with SaaS SOC 2 audits (e.g., Schellman, A-LIGN, Coalfire)
- **Define observation period:** Agree on 6-12 month window (e.g., July 2026 – June 2027)
- **Formal readiness assessment:** Pre-audit gap analysis by the audit firm
- **Maintain controls consistently:** One missed quarterly review or late patch becomes an exception
- **Collect evidence continuously:** Calendar reminders for monthly reconciliations, quarterly reviews, annual tests
- **Prepare report distribution:** Secure NDA-protected portal for sharing SOC 2 report with Fortune 500 clients